SOC L2 Report

Auditor: Amirali Sheikhan

Event ID: 309

Event Time: 2024 -10-11 05:52:00+03:00

Rule: SOC331 - Zebrocy Malware Activity Detected (APT28)

Role: Incident Responder

Alert Type: APT Group

MITRE ARR&CK: T1566.001 - T1059.003 - T1204.002 - T1057 - T1082

Hash:
269908E1B76AFAF1D837BCE28640A1066808AAAC29E6BC6575581DCC907065D0

Hostname: Montague

L1 Notes: An alert was generated by running “2024 Financial Report.exe” on the system. I think that the application came to the system via e-mail from the address “pavlodar.news@bk.ru”. But i could not find the relation of the hash of the relevant application with APT28.

IP Address: 172.16.17.132

Command Line:
C:\Users\LetsDefend\Downloads\2024-financial-report\2024 Financial Report.exe

Trigger Reason: Known hashes associated with Zebrocy malware

Contents

APT 28 3

Tactics, Techniques, and Procedures (TTPs) 3

Investigation: 4

Zebrocy Malware: 4

Capabilities and TTPs 5

Email Security 5

Log Management: 7

Endpoint Security: 8

Processes: 5708 – cmd.exe – 2024 financial Report.exe – cmd.exe /c TASKLIST 8

Conclusion and Containment 9

IoC: 10

APT 28

APT28 (also widely known as **Fancy Bear**, **Sofacy**, **Sednit**, or Microsoft's **Forest Blizzard**) is a highly skilled, state-sponsored cyber espionage group active since at least the mid-2000s.

State Sponsor: Widely attributed by intelligence agencies and cybersecurity firms to the Russian Federation, specifically operating as a cyber unit under the **GRU** (Russia's military intelligence agency, notably linked to **Unit 26165**).

Geopolitical Alignment: Its operations heavily mirror and advance Russian strategic interests—focusing primarily on intelligence collection, political influence, and disrupting entities critical to Western and NATO security.

Sectors: Government ministries, defense and military contractors, diplomatic bodies, international organizations, energy infrastructure, aerospace firms, think tanks, and media outlets.

Geographies: Heavy concentrations across NATO-aligned nations, the United States, European governments (such as Germany and France), and persistent targeting of Ukrainian critical infrastructure and government bodies.

2015 German Bundestag Hack: A massive cyberattack that paralyzed the IT infrastructure of the German parliament, resulting in significant data theft and the exfiltration of emails from lawmakers.

2016 U.S. Election Interference: Compromised the Democratic National Committee (DNC), the Democratic Congressional Campaign Committee (DCCC), and various political figures, followed by the public leaks of stolen documents.

Tactics, Techniques, and Procedures (TTPs)

Initial Access: Heavy reliance on targeted **spear-phishing campaigns**, custom malicious attachments/links, and the exploitation of edge infrastructure and public-facing applications (often leveraging zero-day or recently disclosed vulnerabilities).

Credential Harvesting: Utilizing look-alike domains and spoofed login pages to capture enterprise and cloud credentials, alongside large-scale, automated password spraying.

Custom Malware Arsenal: Employs a broad and frequently updated suite of implants and backdoors—such as *XAgent*, *X-Tunnel*, *SteelHook*, and various modular loaders—designed for cross-platform data exfiltration, persistent control, and lateral movement.

Living off the Land: Frequently abuses native administrative tools like PowerShell, standard Windows command shells, and legitimate utilities to blend in with normal network noise after gaining access.

Investigation:

As L1 has reported an Zebrocy Malware activity by APT 28. The hash provided is 269908E1B76AFAF1D837BCE28640A1066808AAAC29E6BC6575581DCC907065D0.

This hash is reported 49 times in Virus Total database as Zebrocy Trojan which is exe executable file.

The L1 notes “An alert was generated by running “2024 Financial Report.exe” on the system. I think that the application came to the system via e-mail from the address “pavlodar.news@bk.ru”. But I could not find the relation of the hash of the relevant application with APT28”. This notes exactly indicates the exe file which was reported in Virus Total database.

Zebrocy Malware:

Zebrocy (also tracked as *Zekapab*) is a modular Trojan and information-gathering malware family heavily utilized by the state-sponsored cyber espionage group **APT28** (Fancy Bear / Sofacy). Active since at least 2015, Zebrocy is primarily deployed in targeted attacks against government bodies, defense contractors, international organizations, and diplomatic targets, particularly across Eastern Europe, Central Asia, and NATO-allied nations.

Zebrocy campaigns typically deploy in stages using a combination of components:

- **Dropper/Downloader:** Responsible for initial system profiling, gathering environment details, and fetching the primary payload. These often arrive via spear-phishing emails containing malicious attachments (such as weaponized documents, ISO files, or archives using themes like fake NATO training materials or government policies).
- **Backdoor:** Establishes persistence, executes commands, handles data exfiltration, and maintains covert communication with Command and Control (C2) servers.

Capabilities and TTPs

Once running on a compromised host, Zebrocy executes comprehensive automated discovery and collection routines:

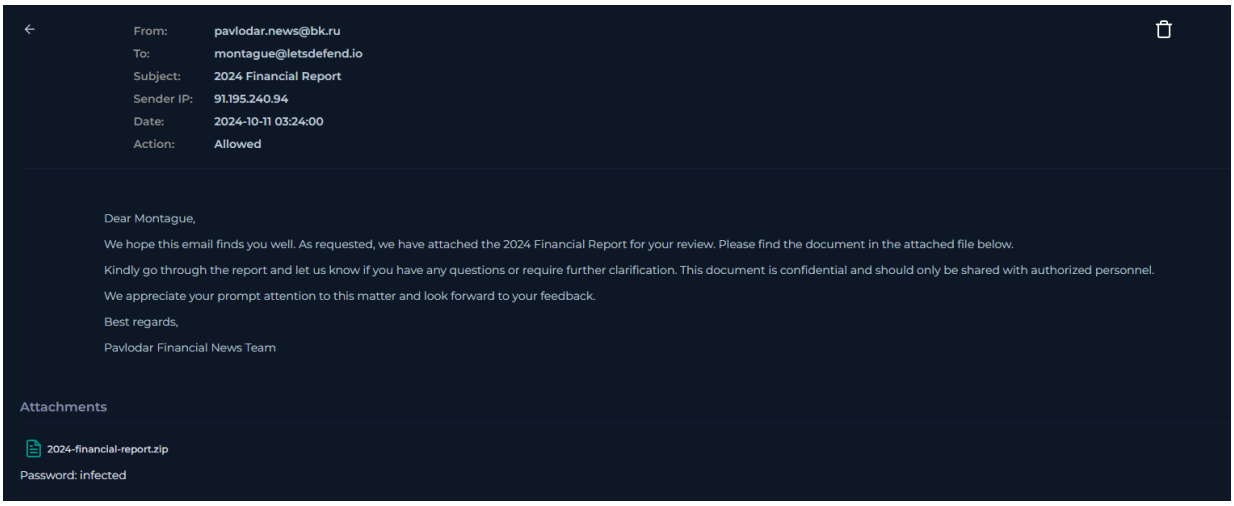
- **System Discovery:** Enumerates system information, running processes (tasklist, wmic), network configuration (ipconfig /all), active network connections (netstat -aon), and local storage volumes.
- **Reconnaissance & Surveillance:** Features functionality to take screenshots of the victim's desktop (in JPEG or BMP formats) and log keystrokes or hook into application-defined windows.
- **Targeted File Harvesting:** Automatically scans directories for specific file extensions associated with sensitive data (e.g., .doc, .docx, .xls, .xlsx, .ppt, .pptx, .pdf, .zip, .rar).
- **Staging and Exfiltration:** Packages collected files into a single local staging archive, obfuscates or encrypts the payload (often using custom string encoding, AES, or SSL), and exfiltrates data via HTTP/HTTPS POST requests to hardcoded IP addresses or C2 domains.
- **Persistence:** Commonly establishes persistence on Windows endpoints by abusing registry run keys or setting user logon scripts (such as modifying HKCU\Environment\UserInitMprLogonScript).

Email Security

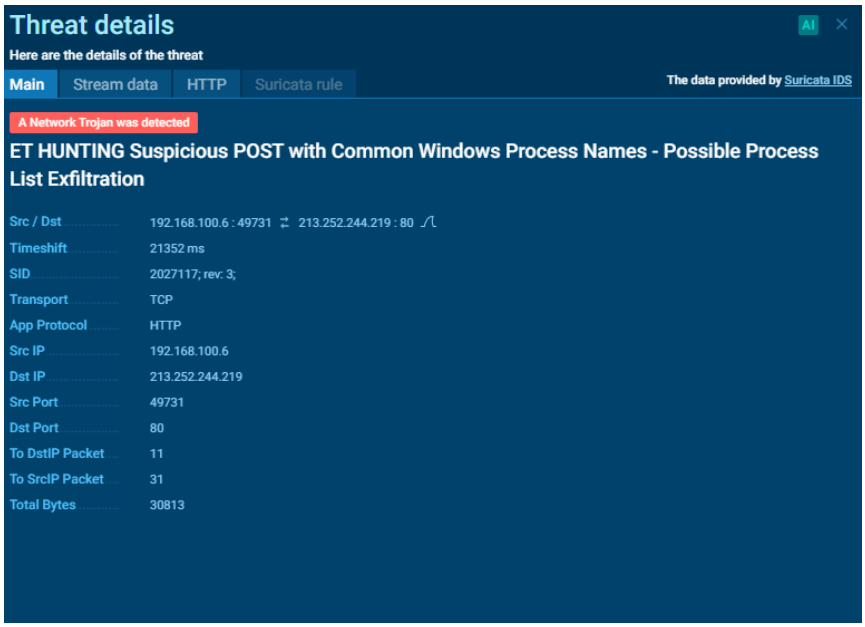
The first step in malware like Trojan is delivery method. As we check in email's the user montague@letsdefend.io has received email from pavlodar.news@bk.ru with subject of 202 Financial Report.

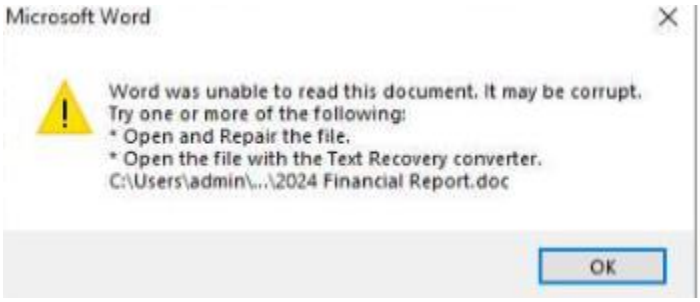
This email is example of APT 28 phishing attack methods. Also email contains and 2024-financial-report.zip with password of infected.

As our investigation we download the zip file and upload it in Any run sandbox.



Any Run confirms that this file is a malware.





As result the email is deleted from the user inbox.

Log Management:

Logs:

Time	Value	Details
2024-10-11 06:52:41	Proxy	Connection to C2 server Destination Address: 3.15.130.156 **URL:** https://files-ld.s3.us-east-2.amazonaws.com/2024-financial-report.zip **Device Action:** Allowed
2024-10-11 06:52:41	OS	**Event ID:** 4688 **New Process Name:** C:\Windows\SysWOW64\cmd.exe **Parent Process Name:** C:\Users\LetsDefend\Downloads\2024-financial-report\2024 Financial Report.exe **ProcessCommandLine** cmd.exe /c TASKLIST cmd.exe /c SYSTEMINFO A new process has been created
2024-10-11 06:52:14	**RAW**	{ "EventID": "11", "EventDescription": "File Created", "Image": "C:\Program Files\7-Zip\7zG.exe", "TargetFileName": "C:\Users\LetsDefend\Downloads\2024-financial-report\2024 Financial Report.exe", "RuleName": "Downloads" }
2024-10-11 06:53:03	OS	**Image:** C:\Users\LetsDefend\Downloads\2024-financial-report\2024 Financial Report.exe **Event ID:** 11 **Target File:** C:\Users\LETSDE~1\AppData\Local\Temp\1\drvmmc.exe File Created

User has successfully connected to C2 server which is and AWS S3 bucket with IP 3.5.130.156 and URL https://files-ld.s3.us-east-2.amazonaws.com/2024-financial-report.zip and downloaded the file. The device action is allowed which did not detect the malware.

A new process has been created with ID 4688 and parent process of financial report.exe.

The malware is executed by user and infected the tmp folder and drvmmc.exe and executed a file in tmp folder so system could not identify it as malware.

Endpoint Security:

Processes:

5708 – cmd.exe – 2024 financial Report.exe – cmd.exe /c TASKLIST

4436 - 2024 Financial Report.exe - explorer.exe

Terminal History:

cmd.exe /c TASKLIST
cmd.exe /c SYSTEMINFO

C:\Windows\system32\cmd.exe /c C:\Windows\system32\reg.exe query hklm\software\microsoft\windows\softwareinventorylogging /v collectionstate /reg:64

C:\Windows\system32\cmd.exe /d /c C:\Windows\system32\silcollector.cmd configure

'powershell "Get-WinEvent -FilterHashtable @(@{ LogName='System'; ProviderName='Microsoft-Windows-Kernel-General'; Id=12; Level=4 }, @{ LogName='System'; ProviderName='Microsoft-Windows-WER-SystemErrorReporting'; Id=1001; Level=2 }) | Sort-Object TimeCreated -Descending" "| Select-Object" "Id, Level, ProviderName, TimeCreated, Properties" "| ConvertTo-Json -Depth 3"

powershell "Get-CimInstance Win32_PnPSignedDriver | Where-Object { $_.DeviceID -eq 'XENBUS\VEN_XS0001&DEV_VBD&REV_00000001_' -or $_.DeviceClass -eq 'Net' -and ($_.Manufacturer -like 'Intel*' -or $_.Manufacturer -eq 'Citrix Systems, Inc.' -or $_.Manufacturer -eq 'Amazon Inc.' -or $_.Manufacturer -eq 'Amazon Web Services, Inc.')}" "| Select-Object" "Description, DriverVersion" "| ConvertTo-Json -Depth 3"

powershell "Get-CimInstance Win32_PnPEntity | Where-Object { $_.Service -eq 'xenvbd' }" "| Select-Object" DeviceID "| ConvertTo-Json -Depth 3"

All these commands shows represent **post-exploitation discovery and environment profiling** commands executed by an attacker or simulated script after gaining access to the endpoint.

Conclusion and Containment

The user was affected by phishing email and executed a malicious malware related to APT 28, malware infected the user machine, and it was not detected by Windows Security.

The user endpoint must be isolated and being clean from malware.

Also user needs to be educated about phishing emails so this incident won't happen in future.

IoC:

Malware Hash:
269908E1B76AFAF1D837BCE28640A1066808AAAC29E6BC6575581DCC907065D0

Attacker Email:

pavlodar.news@bk.ru

C2 Server IP & URL:

3.15.130.156

https://files-ld.s3.us-east-2.amazonaws.com/2024-financial-report.zip